

CÔNG TY CỔ PHẦN VSF VINSMART FUTURE
Số: VSF-QD-DPR-13/2026

QUY ĐỊNH BẢO VỆ DỮ LIỆU CÁ NHÂN, QUYỀN RIÊNG TƯ VÀ XỬ LÝ YÊU CẦU CHỦ THỂ DỮ LIỆU

(Áp dụng cho dữ liệu cá nhân của nhân viên, ứng viên, khách hàng, đối tác và người dùng hệ thống)

Ban hành kèm theo Quyết định số 13/2026/QĐ-VSF ngày 24/06/2026 của Tổng Giám đốc Công ty Cổ phần VSF Vinsmart Future.

Căn cứ ban hành:

- Căn cứ Bộ luật Lao động năm 2019 và các văn bản hướng dẫn thi hành có liên quan;
- Căn cứ Điều lệ tổ chức và hoạt động của Công ty Cổ phần VSF Vinsmart Future;
- Căn cứ nhu cầu quản trị nội bộ, kiểm soát rủi ro và yêu cầu vận hành thực tế của Công ty;
- Theo đề nghị của Khối Hành chính & Tuân thủ, Khối Nhân sự, Khối Tài chính và các đơn vị liên quan.

Phạm vi tài liệu: văn bản này quy định các nguyên tắc, quy trình, thời hạn, biểu mẫu, trách nhiệm và biện pháp xử lý vi phạm liên quan đến việc thu thập, sử dụng, lưu trữ, chia sẻ, xóa và bảo vệ dữ liệu cá nhân.

Thông tin kiểm soát tài liệu	Nội dung
Đơn vị chủ trì	Khối Pháp chế, Tuân thủ & An toàn thông tin
Ngày hiệu lực	01/07/2026
Chu kỳ rà soát	12 tháng/lần hoặc khi có thay đổi pháp luật, mô hình vận hành, hệ thống quản trị
Mức độ lưu hành	Nội bộ VSF Vinsmart Future

MỤC LỤC TÓM TẮT

Chương/Mục	Nội dung chính
Chương I	Quy định chung, phạm vi, đối tượng áp dụng và thuật ngữ
Chương II	Nguyên tắc quản trị, phân quyền, trách nhiệm và phối hợp
Chương III	Quy trình nghiệp vụ, hồ sơ, biểu mẫu, thời hạn xử lý
Chương IV	Kiểm soát, báo cáo, xử lý vi phạm và tổ chức thực hiện
Phụ lục	Bảng checklist, mẫu biểu và sơ đồ quy trình

CHƯƠNG I. NHỮNG QUY ĐỊNH CHUNG

Điều 1. Mục đích

- Thiết lập nguyên tắc xử lý dữ liệu cá nhân minh bạch, đúng mục đích, có kiểm soát và có trách nhiệm.
- Đảm bảo dữ liệu cá nhân chỉ được truy cập bởi người có nhu cầu công việc hợp lệ.
- Chuẩn hóa thủ tục tiếp nhận, xác minh và phản hồi yêu cầu của chủ thể dữ liệu.

Điều 2. Phạm vi và đối tượng áp dụng

- Áp dụng với dữ liệu cá nhân ở dạng giấy, điện tử, âm thanh, hình ảnh, log hệ thống, email, biểu mẫu, CRM, HRM và các ứng dụng nội bộ.
- Áp dụng với tất cả nhân sự VSF và bên thứ ba xử lý dữ liệu thay mặt Công ty.
- Không thay thế quy định an toàn thông tin, sử dụng công cụ AI hoặc bảo mật doanh nghiệp; khi có giao thoa phải áp dụng mức kiểm soát cao hơn.

Điều 3. Giải thích thuật ngữ

Thuật ngữ	Cách hiểu trong tài liệu
Dữ liệu cá nhân	Thông tin gắn với hoặc có thể định danh một cá nhân cụ thể.
Dữ liệu nhạy cảm	Thông tin sức khỏe, tài chính, định danh, sinh trắc học, lương thưởng, kỷ luật hoặc thông tin riêng tư khác.
Chủ thể dữ liệu	Cá nhân mà dữ liệu cá nhân phản ánh.
Xử lý dữ liệu	Thu thập, ghi, lưu, chỉnh sửa, chia sẻ, sử dụng, xóa hoặc tiêu hủy dữ liệu.

Điều 4. Nguyên tắc áp dụng chung

- Chỉ thu thập dữ liệu cần thiết cho mục đích đã thông báo.
- Không sử dụng dữ liệu cá nhân cho mục đích mới nếu chưa có căn cứ hợp lệ hoặc phê duyệt.
- Không nhập dữ liệu cá nhân định danh vào công cụ AI công cộng.
- Dữ liệu cá nhân nhạy cảm phải được phân quyền, mã hóa hoặc lưu trong hệ thống đã được phê duyệt.
- Chia sẻ dữ liệu cho bên thứ ba phải có hợp đồng, cam kết bảo mật và mục đích rõ ràng.

CHƯƠNG II. TRÁCH NHIỆM VÀ PHỐI HỢP

Điều 5. Nguyên tắc phân công trách nhiệm

Mỗi hoạt động phải có một đầu mối chịu trách nhiệm chính, một cấp phê duyệt rõ ràng và một kênh lưu vết chính thức. Không cá nhân, bộ phận nào được tự ý thực hiện công việc vượt phạm vi phân quyền hoặc bỏ qua bước kiểm soát bắt buộc.

Điều 6. Ma trận trách nhiệm RACI

Hoạt động	Bộ phận sở hữu	IT/Security	Pháp chế	HR/CS
Thu thập dữ liệu	R/A	C	C	R
Phân quyền truy cập	R	A	C	C
Yêu cầu chủ thể dữ liệu	C	C	A	R
Sự cố dữ liệu	R	A	C	C
Xóa/ẩn danh dữ liệu	R	R	A	C

Điều 7. Trách nhiệm báo cáo và phản hồi

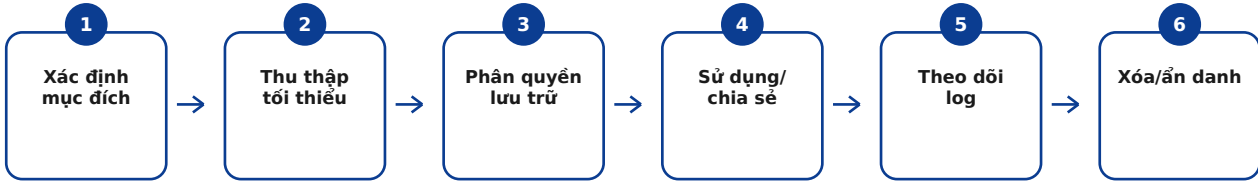
- Mọi nghi ngờ rò rỉ dữ liệu cá nhân phải báo trong 30 phút cho IT Security và Tuân thủ.
- Yêu cầu truy cập/sửa/xóa dữ liệu của cá nhân phải ghi nhận trong sổ theo dõi trong ngày làm việc nhận yêu cầu.
- Bên thứ ba xử lý dữ liệu phải báo sự cố trong vòng 02 giờ kể từ khi phát hiện.

Điều 8. Nguyên tắc phối hợp giữa các bộ phận

- HR xử lý dữ liệu nhân sự; CS/Sales xử lý dữ liệu khách hàng; IT chịu trách nhiệm kiểm soát hệ thống và log truy cập.
- Không bộ phận nào được xuất danh sách dữ liệu cá nhân hàng loạt khi chưa có phê duyệt của quản lý và Tuân thủ.
- Trường hợp yêu cầu liên quan pháp lý, tranh chấp hoặc cơ quan chức năng, Pháp chế là đầu mối chính.

CHƯƠNG III. QUY TRÌNH THỰC HIỆN

Điều 9. Sơ đồ quy trình tổng quát



Điều 10. Các bước nghiệp vụ bắt buộc

Bước 1. Xác định mục đích

- Trước khi thu thập, bộ phận sở hữu phải nêu mục đích xử lý, loại dữ liệu, thời hạn lưu và người truy cập.
- Biểu mẫu thu thập phải tránh hỏi thông tin không cần thiết.

Bước 2. Lưu trữ và phân quyền

- Dữ liệu nhân sự, khách hàng, ứng viên phải lưu trong hệ thống được phê duyệt; không lưu bản chính trên file cá nhân không mã hóa.
- Quyền truy cập được rà soát tối thiểu 06 tháng/lần.

Bước 3. Chia sẻ dữ liệu

- Chỉ chia sẻ dữ liệu theo nguyên tắc cần biết và đúng mục đích.
- File chứa dữ liệu định danh trên 50 người phải đặt mật khẩu hoặc dùng link phân quyền.

Bước 4. Xử lý yêu cầu chủ thể dữ liệu

- Xác minh danh tính trước khi cung cấp hoặc chỉnh sửa dữ liệu.
- Phản hồi yêu cầu tiêu chuẩn trong 07 ngày làm việc; trường hợp phức tạp tối đa 20 ngày và phải thông báo gia hạn.

Bước 5. Xóa/ẩn danh dữ liệu

- Khi hết mục đích hoặc hết thời hạn lưu, dữ liệu phải xóa, ẩn danh hoặc chuyển lưu trữ theo quy định hồ sơ.

CHƯƠNG III. QUY ĐỊNH NGHIỆP VỤ CỤ THỂ

Điều 11. Dữ liệu nhân viên và ứng viên

- Hồ sơ ứng viên không trùng tuyển lưu tối đa 12 tháng nếu không có sự đồng ý lưu lâu hơn.
- Bảng lương, đánh giá, kỷ luật, thông tin sức khỏe chỉ HR, Tài chính và người được ủy quyền được truy cập.
- Không gửi bảng lương, CCCD, số tài khoản qua nhóm chat chung.

Điều 12. Dữ liệu khách hàng và người dùng

- Danh sách khách hàng xuất từ CRM phải ghi rõ mục đích, người nhận và thời hạn sử dụng.
- Không dùng dữ liệu khách hàng thật trong demo, đào tạo hoặc kiểm thử nếu chưa ẩn danh.
- Khi gửi email hàng loạt phải dùng công cụ được phê duyệt, tránh lộ danh sách người nhận.

Điều 13. Bên thứ ba xử lý dữ liệu

- Bên thứ ba phải ký thỏa thuận xử lý dữ liệu và chỉ xử lý theo chỉ dẫn của VSF.
- Không chuyển dữ liệu ra ngoài lãnh thổ hoặc nền tảng không được phê duyệt khi chưa có đánh giá rủi ro.

Điều 14. Quản lý log và truy vết

- Hệ thống quan trọng phải lưu log truy cập tối thiểu 12 tháng.
- Truy cập bất thường, tải dữ liệu số lượng lớn hoặc ngoài giờ phải được cảnh báo và rà soát.

CHƯƠNG III. HẠN MỨC, SLA VÀ ĐỊNH MỨC KIỂM SOÁT

Điều 15. Bảng định mức áp dụng

Tình huống	Yêu cầu kiểm soát	Thời hạn/SLA	Phê duyệt
Xuất dữ liệu < 50 cá nhân	Ghi rõ mục đích	Trong ngày	Trưởng bộ phận
Xuất dữ liệu từ 50 cá nhân trở lên	Mã hóa/ phân quyền file	Trước khi gửi	Trưởng bộ phận + Tuân thủ
Yêu cầu sửa/xóa dữ liệu	Xác minh danh tính	07 ngày làm việc	Tuân thủ
Sự cố dữ liệu	Kích hoạt phản ứng sự cố	Báo trong 30 phút	IT Security + Tuân thủ

Điều 16. Cơ chế nâng cấp xử lý

- Rò rỉ dữ liệu nhạy cảm phải báo Tổng Giám đốc và kích hoạt nhóm xử lý sự cố dữ liệu.
- Yêu cầu từ cơ quan nhà nước phải chuyển Pháp chế trong 02 giờ làm việc.
- Nếu phát hiện quyền truy cập không còn phù hợp, IT phải thu hồi trong 01 ngày làm việc.

Mình họa mức ưu tiên/định mức kiểm soát

Tối thiểu hóa		25
Phân quyền		30
Mã hóa		20
Log/giám sát		25

CHƯƠNG III. HỒ SƠ, BIỂU MẪU VÀ LƯU TRỮ

Điều 17. Hồ sơ bắt buộc

Hồ sơ	Người lập	Thời hạn lập	Lưu giữ
Sổ xử lý dữ liệu	Bộ phận sở hữu	Khi phát sinh	03 năm
Phiếu yêu cầu chủ thể dữ liệu	Tuân thủ/HR/CS	Ngay khi tiếp nhận	05 năm
Biên bản chia sẻ dữ liệu	Bộ phận sở hữu	Trước khi chia sẻ	05 năm
Biên bản sự cố dữ liệu	IT Security	Trong 24 giờ	10 năm

Điều 18. Nguyên tắc lưu trữ

- Dữ liệu nhạy cảm phải lưu trong hệ thống phân quyền, không lưu trong thư mục mở toàn công ty.
- File tạm chứa dữ liệu cá nhân phải xóa trong vòng 05 ngày làm việc sau khi hoàn thành mục đích.
- Sao lưu dữ liệu cá nhân tuân theo chính sách backup và thời hạn lưu giữ tương ứng.

Điều 19. Quy định về biểu mẫu

- BM.DPR.13.01 - Phiếu đăng ký hoạt động xử lý dữ liệu cá nhân.
- BM.DPR.13.02 - Phiếu yêu cầu truy cập/sửa/xóa dữ liệu.
- BM.DPR.13.03 - Biên bản chia sẻ dữ liệu với bên thứ ba.
- BM.DPR.13.04 - Báo cáo sự cố dữ liệu cá nhân.

CHƯƠNG IV. ĐIỀU CẤM VÀ XỬ LÝ VI PHẠM

Điều 20. Các hành vi không được thực hiện

- Thu thập dữ liệu cá nhân không phục vụ mục đích công việc.
- Tự ý tải, sao chép, gửi dữ liệu cá nhân ra tài khoản cá nhân hoặc thiết bị không được phê duyệt.
- Nhập dữ liệu định danh vào công cụ AI công cộng hoặc website không được kiểm soát.
- Cung cấp dữ liệu cho bên thứ ba khi chưa có căn cứ, hợp đồng hoặc phê duyệt.

Điều 21. Bảng xử lý vi phạm tham chiếu

Hành vi	Biện pháp xử lý	Ghi chú
Gửi nhầm dữ liệu cá nhân	Báo cáo sự cố, nhắc nhở/cảnh cáo	Tùy loại dữ liệu và tác động
Xuất dữ liệu không phê duyệt	Thu hồi file, xử lý kỷ luật	Có thể khóa quyền truy cập
Rò rỉ do cố ý	Kỷ luật nghiêm trọng, bồi thường	Có thể chấm dứt HĐLĐ
Che giấu sự cố dữ liệu	Cảnh cáo hoặc cao hơn	Tăng nặng nếu gây thiệt hại

Việc xử lý vi phạm phải bảo đảm nguyên tắc khách quan, có hồ sơ chứng minh, cho phép người liên quan giải trình và không thay thế các nghĩa vụ bồi thường thiệt hại nếu có.

PHỤ LỤC 01. CHECKLIST THỰC HIỆN

STT	Hạng mục kiểm tra	Đạt/Không	Ghi chú
1	Mục đích xử lý dữ liệu đã rõ ràng		
2	Chỉ thu thập trường dữ liệu cần thiết		
3	Quyền truy cập đã được phân quyền		
4	File chia sẻ được mã hóa/phân quyền		
5	Có thời hạn lưu và kế hoạch xóa/ẩn danh		
6	Không dùng dữ liệu thật trên AI/demo/test		

Hướng dẫn sử dụng checklist

- Checklist dùng trước khi triển khai biểu mẫu mới, chiến dịch mới hoặc tích hợp hệ thống có dữ liệu cá nhân.
- Bộ phận sở hữu chịu trách nhiệm cập nhật checklist khi mục đích xử lý thay đổi.

Người thực hiện và người phê duyệt chịu trách nhiệm ký xác nhận trên biểu mẫu điện tử hoặc bản giấy theo đúng thẩm quyền trước khi chuyển sang bước tiếp theo.

PHỤ LỤC 02. BIỂU MẪU MINH HỌA VÀ TỔ CHỨC THỰC HIỆN

A. Mẫu phiếu/biên bản tóm tắt

Mã biểu mẫu	BM.DPR.13.02
Người yêu cầu	
Loại yêu cầu	Truy cập / Chính sửa / Xóa / Hạn chế xử lý
Dữ liệu liên quan	
Kết quả xác minh danh tính	Đạt / Không đạt
Thời hạn phản hồi	07 ngày làm việc, trường hợp phức tạp tối đa 20 ngày

B. Hiệu lực thi hành

- Quy định có hiệu lực từ ngày 01/07/2026.
- Trong 30 ngày kể từ ngày hiệu lực, các bộ phận phải rà soát thư mục và file chứa dữ liệu cá nhân.
- IT Security và Tuân thủ tổ chức kiểm tra định kỳ tối thiểu 02 lần/năm.

Nơi nhận	Trách nhiệm
Toàn thể CBNV VSF	Đọc, hiểu và tuân thủ
Khối Pháp chế, Tuân thủ & An toàn thông tin	Chủ trì hướng dẫn, giải đáp và rà soát định kỳ
Khối Hành chính & Tuân thủ	Lưu bản gốc, công bố trên hệ thống tài liệu nội bộ

NGƯỜI SOẠN THẢO	KIỂM SOÁT TUÂN THỦ	TỔNG GIÁM ĐỐC
(Ký, ghi rõ họ tên)	(Ký, ghi rõ họ tên)	(Ký, đóng dấu)